

Gestão de Cibersegurança

Universidade do Minho

2025/2026

Practical Lab Exercises #03

pg60986 - João Afonso Carneiro Araújo e Silva - MCS

pg59797 - Rui Pedro Ramos Carvalho - MCS

pg60307 - Tiago Leal Baganha - MCS

1.

1. Dimensão Técnica

A **dimensão técnica** dos sistemas de informação refere-se ao hardware, software e controlos de rede que protegem os dados e os sistemas contra acesso não autorizado ou ataques. Neste caso o target demonstrou profundas fraquezas tanto na configuração do sistema, como na resposta operacional.

O Target realizou vários investimentos em “Firewalls”, deteção de “Malware”, deteção de intrusões e prevenção de perdas de dados, no valor 1,6 milhões de dólares. Este sistema de segurança estava de acordo com as normas de proteção dos dados dos consumidores, além disso estas tecnologias eram utilizadas pela CIA e pelo pentágono.

Contudo, este sistema avisava incorretamente determinado tráfego de emails como sendo malware, então a equipa de segurança desativou esse sistema de deteção de “Malware”. Para além disso ainda ignoraram os avisos do alerta de intrusos, que permitiu aos atacantes instalar um software de visualização de dados dos clientes, o que comprometeu a segurança da empresa e dos clientes. Apesar de o Target inicialmente parecer preparado para um ciberataque, os resultados foram catastróficos, devido à má utilização das ferramentas.

2. Dimensão Formal

A **dimensão formal** diz respeito às regras, procedimentos, políticas e estruturas de governação, que orientam as operações de segurança da informação. No caso do Target apesar das políticas estarem implementadas, os funcionários da empresa não seguiram essas políticas, ignoraram-se os avisos do alerta de intrusos, desativou-se a remoção automática de “Malwares”, houve segmentação de rede insuficiente, o que levou a uma gestão de terceiros fraca. Como foi explicado no artigo, uma empresa para manter o seu negócio protegido é necessário atribuir um CIO ou CTO que comunique com os gestores da empresa, para conversar e estabelecer planos de segurança, muitas das vezes o responsável pela segurança da empresa não tem um papel ativo na gestão e na estratégia da empresa, além disso uma das melhores práticas e mais inovadores é utilizar os membros da própria empresa ou então contratar outra empresa para verificar falhas existentes no sistema.

3. Dimensão Informal

A **dimensão informal** diz respeito ao comportamento humano e às atitudes dos funcionários face à segurança da informação. No caso da Target, mesmo dispondo das melhores tecnologias e das melhores estruturas políticas, tudo pode falhar se as pessoas não estiverem informadas. Por exemplo, os funcionários ignoraram vários avisos do

sistema automático de detecção de malware, o que revela falta de responsabilidade e de formação relativamente às suas responsabilidades de cibersegurança. Esta situação levou a empresa a investir 5 milhões de dólares por ano em formação dos seus funcionários, focada em boas práticas e na consciencialização para questões de cibersegurança. Como referido no artigo, um dos aspetos em que essas formações devem incidir são os ataques de engenharia social, que consistem em enganar as pessoas e levá-las a revelar as suas credenciais.

4. Dimensão Regulatória

A **dimensão regulatória** refere-se às estruturas legais e à forma como as empresas aplicam essas normas. Após a violação dos dados dos consumidores, a Target enfrentou mais de 90 processos judiciais. A empresa divulgou que os custos associados à violação ascenderam a 290 milhões de dólares. Como existem 47 leis diferentes relativas a perdas de dados, torna-se difícil para as empresas saberem qual devem seguir, o que gera confusão e inconsistência. Tal como referido no artigo, após este incidente houve uma alteração legislativa e, agora, só são permitidos processos quando existem danos económicos resultantes da perda de dados.

[Contagem de palavras: 562 palavras]

2.

Controlo	Tipo	Propósito
Firewalls, deteção de intrusos, deteção de “Malware” e prevenção de perda de dados	Técnica	Prevenção
Sistemas de segurança com as mesmas normas de proteção de dados estipulada pela fábrica	Técnica	Prevenção
Alertas/avisos de segurança	Técnica	Detetar
Segmentação de rede	Técnica	Prevenção
Dificuldade das empresas a escolher as normas a aplicar à sua empresa	Regulatório	Diretivo
Dependendo das jurisdições as empresas são ou não obrigadas a pagar pelos danos dos seus clientes	Regulatório	Diretivo/Reação
São apenas permitidos processos quando afetam danos económicos dos seus clientes	Regulatório	Diretivo
Formação relativamente às responsabilidades de cibersegurança	Informal	Aprender
Desenvolver planos de cibersegurança	Formal	Diretivo/Estrutural
É necessário atribuir um CIO ou CTO com autoridade para discutir com os gestores	Formal	Estrutural
Testes de intrusão com membros da própria empresa ou contratação de outra empresa	Formal	Detetar
Responder a falhas	Formal	Reação
Gestão das responsabilidades dos trabalhadores	Formal	Estrutural